QCM **TEST**

Part I (For Grades F to E)
DD2395 Computer Security
Exam 2019-01-14, 14.00 – 17.00

This is a closed-book exam, no material (books, articles, laptops, phones, or any other electronic devices, etc.) permitted. Questions using the sign ♣ may have zero, one or several correct answers (true statements in that category). The option None of these answers are correct *exists to detect the difference between a question with no true statements and one that has not been answered.* ***Mark all true statements on the separate answer sheet by completely filling in the corresponding box. Hand in your exam sorted like this: cover page, Part I: the multiple-choice answer sheet, Part II written responses.***

Question 1 ♣ Concepts, CIA

- [A] The main security properties (CIA) are confidentiality, integrity, and authenticity.
- [B] Eavesdropping is an attack on integrity.
- [C] The principle of least privilege means that the capabilities of a user are reduced to what is needed for the current task. E.g., if a user is now only reading a file, the system should remember this and by default only offer read access the next time, thus requiring that the user make it explicit if they want to write or execute next time.
- [D] The main phases and categories of computer security as defined in the course are prevention (make sure attacks don't happen), delegation (manage access rights from programs to processes to threads), responsibility (policies for humans), and reinstallation (clean installations after attacks).
- [■] Encryption is one way to protect confidentiality.
- [F] *None of these answers are correct.*

Question 2 ♣ Authentication.

- [■] Authentication has two parts, identification (who is the subject, e.g., user id) and verification (making sure they really are who they claim to be).
- [B] Authentication always requires proving that you know a secret, e.g., a password.
- [C] The reason for individual salts for hashing passwords is to compensate for different lengths of passwords, which would otherwise make them easier to guess.
- [D] *None of these answers are correct.*

Question 3 ♣ Cryptography

- [■] With symmetric encryption, the sender and receiver use the exact same secret key.
- [B] Strong collision resistance means that a secure hash function withstands brute force attacks to find a collision with a given hash value even from attackers with high computational power.
- [C] For digital envelopes to work, the sender and receiver first need to agree on a shared key.
- [■] If Alice sends a message to Bob using public-key cryptography, Bob needs to have both his own private key and Alice's public key to decrypt the message and be sure that it is from Alice.
- [E] *None of these answers are correct.*

Question 4 ♣ Buffer overflow

- [A] A heap overflow can be used to alter the control flow of a program because the return addresses of function calls are saved in the heap.
- [■] If the interpreter or JIT is correct, the usage of memory safe languages (like Java) prevents buffer overflows.
- [C] Stack canaries can be used to detect all possible buffer overflows.
- [■] Functions check stack canaries (to be unmodified) just before they return.
- [E] *None of these answers are correct.*

Question 5 ♣ Malware

- [■] The **main** propagation strategy of a worm consists of exploiting vulnerabilities of remote programs.
- [B] The **main** propagation strategy of a virus consists of exploiting vulnerabilities of remote programs.
- [C] To detect the presence of a polymorphic virus it is enough to scan all executables and search for a fixed binary code.
- [■] An antivirus using generic description emulates the CPU, executes the virus in the interpreter, and waits that the virus decrypts itself to identify the malicious payload.
- [E] *None of these answers are correct.*

Question 6 ♣ Denial of Service

- [■] Flooding (non-distributed) attacks like ICMP flood require that the attacker has more bandwidth than the victim.
- [B] A successful DOS is a loss of confidentiality.
- [■] In a TCP/IP SYN spoof attack the attacker attempts to fill the TCP connection table of the victim.
- [D] *None of these answers are correct.*

Question 7 ♣ System security

- [A] Guard pages are regions of virtual memory whose execution is forbidden, but writable accesses are permitted.
- [■] In case of executable address space protection, the heap is configured as writable and non-executable.
- [C] Address space randomization counters buffer overflows because it prevents an attacker from knowing the size of the buffers.
- [D] *None of these answers are correct.*

Question 8 ♣ Access Control

- [■] In multi-level security, users (subjects) have clearance levels and resources (objects) have classification levels. What a user with a specific clearance can do to a resource with a specific classification depends on the security model.
- [B] Discretionary access control means that it's up to owner of a resource (e.g., a file) to decide whether an access request is checked.
- [■] Role-based access control assigns rights to roles and maps users to roles. Roles can be hierarchical.
- [D] *None of these answers are correct.*

Question 9 ♣ Intrusion Detection, Firewalls

■ White listing will let less bad traffic through than blacklisting.

B The two main approaches to intrusion detection are signature based (meaning only install programs that are authentic, e.g., checked the message digest or digital signature) and anomaly based (meaning using a list of malicious programs that do not behave like normal programs and detecting if a program is on the list)

C DMZ (demilitarized zone) means that there is no firewall or intrusion detection system set up around it.

D *None of these answers are correct.*

Question 10 ♣ Side-channels

A A side-channel attack usually relies on a buffer overflow.

■ Constant time programming is a programming technique guaranteeing that no condition of branches and no index of array depend on secret information.

C Cache partitioning prevents an attacker to extract secret information by analyzing execution time of the victim (time-driven attacks).

■ A side-channel attack is based on information gained from the execution of a system, for instance by measuring its execution time.

E *None of these answers are correct.*

Question 11 ♣ Privacy

■ The GDPR (general data protection regulation) has one set of rules for all EU countries and it even applies to companies outside the EU if they offer services in the EU.

B Purpose binding means that once a user (data subject) has consented to their data being analyzed and used by an organization or company (data controller , data processor) for a given purpose, they have no right to get their data deleted.

■ Privacy concerns not only the data itself (e.g., contents of files or messages) but also metadata, meaning data about the data.

D *None of these answers are correct.*

Question 12 ♣ Web Security

■ One way to prevent SQL injection is to use parameterized queries.

B Cross-site scripting takes advantage of a user being authenticated for a session with a server and makes it look like a transaction was initiated by the authenticated user.

■ One of the OWASP Top 10 most critical web application security risks is broken access control. There are many ways to bypass access control, such as by manipulating things like the URL, request parameters or cookies.

D *None of these answers are correct.*

Question 13 ♣ Social Engineering, Human Factors, Policies

■ Social engineering exploits often positive human traits, not lack of intelligence.

B The security policy is best developed by one or two security experts, as users or managers usually do not know enough about security and tend to increase the complexity of the document which in turn increases the probability of errors.

■ An organizational security policy is a formal statement of rules by which people given access to the organization's technology and information assets must abide.

D *None of these answers are correct.*

Question 14 ♣ Hot Topics: blockchain, DevOps, 5G

■ Blockchains rely on consensus (a majority must agree on something) and on proof of work (proving that one has dedicated processing power, although there are alternative proposals for proofs).

B DevOps security defines the set of options developers need to integrate into programs so that users can configure the program settings in a secure way.

C Mobile network security in 4G/5G is about securing the access to the radio network, all other functions, such as identity management, privacy, or confidentiality and integrity on the wired network (core network or Internet) are done by the application (banking, social networks, etc.).

D *None of these answers are correct.*

Part I Answer Sheet

Answers must be given exclusively on this sheet: answers given on the other sheets will be ignored.

0	0	0	0
1	1	1	1
2	2	2	2
3	3	3	3
4	4	4	4
5	5	5	5
6	6	6	6
7	7	7	7
8	8	8	8
9	9	9	9

⟵ please encode the last 4 digits of your person number by filling the corresponding boxes and write your first and last names below.

Firstname and lastname:

.....

.....

Answers:

Question 1: A B C D ■ F

Question 2: ■ B C D

Question 3: ■ B C ■ E

Question 4: A ■ C ■ E

Question 5: ■ B C ■ E

Question 6: ■ B ■ D

Question 7: A ■ C D

Question 8: ■ B ■ D

Question 9: ■ B ■ D

Question 10: A ■ C ■ E

Question 11: ■ B ■ D

Question 12: ■ B ■ D

Question 13: ■ B ■ D

Question 14: ■ B C D



Part II (For Grades D to B)
DD2395 Computer Security
Exam 2019-01-14, 14.00 – 17.00

This is a closed-book exam, no material (books, articles, laptops, phones, or any other electronic devices, etc.) permitted. Please answer in English if you can, only answer in Swedish if you must. Hand in your exam sorted like this: cover page, Part I: the multiple-choice answer sheet, Part II: your written responses to the questions below.

This part is only graded if Part I resulted in an E. Each question is worth 2 points. Bonus points that have not been used up in the Part I of the exam (multiple choice, to get grade E) can be used as points here. The preliminary grading is as follows:

- D: 4-7 points
- C: 8-11 points
- B:12 or more points.

includes solutions.

1 Denial of service. A news feed service S allows clients to subscribe to news published by content providers.
The system implements the following protocol:

- In order to subscribe to a topic T, a client C_i sends the UDP message IP_i, IP_S, T to S, where IP_i is the IP of the client and IP_S is the IP of the server
- In order to publish a news, a publisher P_j sends the UDP message $IP_j, IP_S, N, T_1, \ldots, T_n$ to S, where IP_j is the IP of the publisher, IP_S is the IP of the server, N is the content of the news, and $T_1, \ldots T_n$ is a list of topics.
- As soon as a new news is published, the server sends a UDP message IP_S, IP_i, D to every client that has been registered for at least one of the relevant topics

Describe how this system can be abused by a malicious user in order to perform a DOS of the server S. Assume that the attacker has less bandwidth than the victim. Describe how this vulnerability can be countered
Solution:
Attacker spoofs IP of several clients C_i and register C_i to hundreds of topics. Then It spoofs the IP of P_j and publishes an article with hundreds of topics. This forces the server to send hundreds of messages to several clients.
Alternatively, he can just use all the memory of the server (by continuing subscribing users)
Use TCP or some sort of authentication.

2 Hash functions. Let $H(x_1, x_2, \ldots, x_n) = \sum_{i=1\ldots n} i * x_i \mod 2^{128}$ be a function that takes an input consisting of arbitrary n blocks of 128 bits and returns the sum (in unsigned 128 bit arithmetic) of the product (in unsigned 128 bit arithmetic) of the block content and block index. For example

- $H(x_1, x_2) = x_1 + 2 * x_2 \mod 2^{128}$
- $H(x_1, x_2, x_3) = x_1 + 2 * x_2 + 3 * x_3 \mod 2^{128}$

Is H a secure hash function? For each requirement of secure hash functions, disprove the requirement or argue why the requirement is met.

Solution:

It is not one way: given h it is easy to find x such that H(x) = h. Just use x := h. It is not weak collision resistant: given x = (x1, ... xn) it is easy to find y <> x such that H(x) = H(y). Use y = (x1, ... xn,0)

3 Buffer overflow. (1) Describe the content of the stack while `chec_pwd` is executed. (2) Write an input for the program (different than "12345") that makes the program executing `do_something` and explain why this happens. (3) Explain how this problem can be fixed.

```
int check_pwd(char * pwd) {
  int result;
  char input[10];
  result = 0;
  gets(input);
  If strcmp(input, pwd) == 0
    result = 1;
  Return result;
}

void main() {
  Int auth = check_pwd("12345");
  If (auth)
    do_something();
}
```

Solution:
1)

1. return address
2. frame ptr
3. pwd
4. result
5. input [10 bytes]

2) a) provide 11 bytes of text, last byte being different than null. This changes result to 1 b) provide $10 + 4 + 4 + 4+$ address of `do_something` c) provide $10 + 4+$ address of input. This change pwd to point to input. Notice that pwd is a pointer, not a buffer of chars.
3) use safe API or stack canary (for 2)

4 **Authentication: Passwords.** You have been put in charge of implementing password authentication for a web service as one part of two-factor authentication (the latter is done by someone else). List your design choices (password storage, protection, format, instructions to users) and for each briefly explain why you made them (i.e., what kind of attack you counter by this choice).
Solution:

- access control to protect access to the password file (to avoid offline attacks)
- hashed with secure hash function, not stored in plain text (to avoid leaking all passwords if access control fails)
- individual salts (to avoid leaking more than one password if they use the same, and to prevent rainbow tables)
- not make it too difficult for users to create a password, no unreasonable requirements (to avoid users writing down their passwords)
- limit attempts or rate limit (to avoid password guessing)

5 Side channels. Let a system use a shared data cache (no instruction cache) of 128 bytes, 2 lines, 64 bytes per line. The cache is directly mapped. Two arrays M1 and M2 consisting of 16 entries of 4 bytes. The entries of each array are allocated on the first cache line. All other variables are allocated on the second line. Finally, assume that $C < 16$ and that all variables are secret.

```
A = M1[C]
A += M2[C]
If B
  A += M1[C]
else
  A += M2[C]
```

Can a time driven attack (i.e. by measuring victim execution time and assuming that execution time only depends on number of cache misses/hits) extract information about the variables of this program? If yes, explain the attack and describe how you can fix the program or prevent the attack; if not, motivate why this program is secure.
Can an access driven attack (i.e., measuring cache lines evicted by the victim) extract information about the variables of this program? If yes, explain the attack and describe how you can fix the program or prevent the attack; if not, motivate why this program is secure.
Solution:
Time driven attack: Notice that the two arrays collide, therefore only one can be in the cache. After the first two instructions M2 is in the cache. An the number of cache misses is constant. For the second part if B = false then there is no cache miss, otherwise there is one.
Possible fix:

```
A1 = M1[C]
A2 = M2[C]
a += B*A1 + (1-B)*A2
```

Access driven attack: Assuming that attacker cannot share memory with the victim no, Always the same cache lines are evicted. However, if we assume that the attacker shares memory with the victim, then he can discover if M1 or M2 is in the cache.

6 Multi-level security: Bell La Padula. Notation: current state of the system (b, f, H) where b is the currently active accesses, set of triples of the form (s, o, a) subject=user, object = resource, a = access mode (read, write (implies read), execute, append (write-only))
f are the functions $f_s(s)$ = max security clearance of subject s, $f_c(s)$ = current security clearance of subject s, $f_o(o)$ = classification level of object o.
H is the hierachy of levels.
For this exercise, you can assume that the ds-property is satisfied, as there is no discretionary access control or compartments and thus no access control matrix M.
The current state of the system is instantiated as follows.

s	Alice	Bob	Carol
f_s(s)	top secret	secret	confidential
f_c(s)	top secret	confidential	confidential

o (files)	plan	budget	rumors	official
f_o(o)	top secret	secret	confidential	unclassified

b	Alice	Bob	Carol
plan	write		
budget			
rumors		read	
official			

H = top secret>secret>confidential>unclassified. b = (Alice, plan, write) and (Bob, rumors, read)
Using the notation and given subject clearances and object classification levels above, decide for each of the following access requests whether it should be granted and formally state which BLP rule is violated in case access is denied.

1. Alice, rumors, read
2. Alice, official, write
3. Bob, budget, write
4. Carol, budget, append

Solution:
no read up, no write down:

1. Alice, rumors, read: allow. ss property $f_s(Alice) >= f_o(rumors)$
2. Alice, official, write: deny. * property $f_c(Alice) > f_o(official)$
3. Bob, budget, write: deny. * property $f_c(Bob) != f_o(budget)$
4. Carol, budget, append. allow. * property, $f_c(Carol) <= f_o(budget)$

7 Firewalls. You are newly hired as "security wizard" for *Restorio!*, a startup company that offers online backup solutions for private individuals in Sweden. The company has been running for several months, grown fast and already has 50 employees, but there is no firewall installed. Briefly describe what considerations you take into account for equipping the company with firewall protection and justify your choices. Draw a sketch of your plan for firewall placement and type.

Solution:

Here it is important to explain your choices, where to place them, whether to have a DMZ and what that means, at what network layer to deploy, how many, how to deal with policie, cost, and maintenance (i.e., just saying put firewalls everywhere and all types is not a good idea).